

CYBER THREAT INTELLIGENCE REPORT

CTI-2026-0526-KIMSUKY-PEBBLEDASH

김수키 Kimsuky(APT43)의 PebbleDash·AppleSeed 신규 툴셋 분석

Rust 기반 백도어 등장, VSCode-Cloudflare 터널링 악용, 그리고 LLM 생성 코드의 흔적

배포 저장소 github.com/gameworkerkim/CYBER-THREAT-INTELLIGENCE-REPORT

문서 분류	TLP:CLEAR — 공개 배포 가능 / 외부 공개 분석 기반
위협 행위자	Kimsuky (APT43, Ruby Sleet, Black Banshee, Sparkling Pisces, Velvet Chollima, Springtail)
귀속 국가	북한 (DPRK) — 정찰총국(RGB) 산하로 평가
주요 표적	대한민국 공공·민간 부문 (정부·국방·의료·기계·에너지), 일부 브라질·독일 국방
작성일	2026년 5월 26일
작성자	Dennis Kim, 독립 CTI 분석가
1차 출처	Kaspersky GReAT (Securelist, 2026-05-14)
신뢰 수준	귀속: 중상(Medium-High) / 기술 분석: 높음(High)

목차

목차	2
1. 핵심 요약 (Executive Summary)	3
2. 배경 - Kimsuky와 두 악성코드 계열	4
3. 위협 행위자 프로파일: Kimsuky(김수키)	5
3.1 조직 개요와 별칭	5
3.2 표적과 전략적 목적	5
3.3 주요 해킹 사건 연혁	6
3.4 이 조직은 얼마나 위험한가	6
3.5 제재 및 국제 대응 동향	7
4. 초기 침투 (Initial Access)	8
4.1 드롭퍼 실행 메커니즘	8
5. 신규 악성코드 심층 분석	9
5.1 HelloDoor — Kimsuky 최초의 Rust 기반 백도어	9
5.2 httpMalice — 최신 PebbleDash 백도어 변종	9
5.3 MemLoad → httpTroy 체인	10
5.4 AppleSeed 계열 — GPKI 인증서 탈취의 시그니처화	10
6. 분석 초점 - 왜 Rust였는가?	11
6.1 탐지 회피 - 기존 시그니처의 무력화	11
6.2 LLM 보조 개발 - 진입 장벽을 낮춘 AI	11
6.3 부차적 동기 - Rust 자체의 이점(단, 제한적)	12
7. 후속 침투 - 정상 도구(LotL) 악용	12
7.1 VSCode 원격 터널링 악용	12
7.2 DWAgent 원격 관리 도구 악용	13
8. 인프라 및 피해 양상	13
8.1 귀속 (Attribution)	14
9. MITRE ATT&CK 매핑	14
10. 탐지 및 대응 권고	15
10.1 즉시 탐지 포인트	15
10.2 조직 차원 대응	15
11. 한국 정부 및 관계 당국의 대책	15
10.1 침해사고 신고 창구	15
10.2 법적 신고 의무 (정보통신망법)	16
10.3 정부의 선제적, 외교적 대응	16
12. 분석가 평가 (Analyst Assessment)	17
부록 A. 침해 지표 (IOC)	18

A.1 파일 해시 (MD5)	18
A.2 도메인 및 C2	18
부록 B. 출처	19

1. 핵심 요약 (Executive Summary)

2026년 5월 14일 Kaspersky GReAT(Global Research & Analysis Team)는 북한 연계 위협 행위자 **Kimsuky(APT43)**의 최근 캠페인을 분석한 보고서를 공개했다. 본 CTI는 해당 1차 분석을 한국 방어자 관점에서 재구성하고, **PebbleDash** 및 **AppleSeed** 두 악성코드 계열의 신규 변종과 전술 변화를 정리했다.

핵심은 단순한 신규 악성코드 출현이 아니라 **공격 도구의 질적 진화**다. Kimsuky가 그동안 거의 쓰지 않던 **Rust 언어**로 첫 백도어(HelloDoor)를 제작했고, 정상 도구인 **VSCode** 원격 터널링과 **Cloudflare Quick Tunnel**을 C2 은닉에 활용했으며, 무엇보다 **악성코드 코드 내부에서 LLM이 생성한 것으로 보이는 흔적**이 확인되었다는 점이다.

주요 발견 사항

- 초기 침투는 문서로 위장한 첨부파일(JSE/.PIF/.SCR/.EXE)을 동반한 정교한 **스피어피싱** 및 메신저 접근으로 이루어진다.
- 드롭퍼가 전달하는 악성코드는 **PebbleDash 계열(HelloDoor, httpMalice, MemLoad→httpTroy)**과 **AppleSeed 계열(AppleSeed, HappyDoor)**로 양분된다.
- **HelloDoor**는 Kimsuky 최초의 Rust 기반 DLL 백도어로, 개발 초기 단계로 평가되며 LLM 생성 코드 정황(이모지 디버그 로그)이 포착됨.
- AppleSeed 계열은 한국 정부 공인인증 디렉터리인 **c:\GPKI** 탈취를 시그니처 기능으로 확립 — 데이터 유출로 무게중심 이동.
- PebbleDash 계열은 **국방·군 부문**에 집중하며, 한국 외 브라질, 독일 국방 조직까지 표적 확대.
- 후속 침투(post-exploitation)에 정상 도구 **VSCode**와 **DWAgent**를 악용 — 전통적 C2 탐지 우회 목적.

위협 스냅샷

신규성	표적 적합성(한국)	탐지 난이도
높음 — Rust-LLM·터널링 도입	매우 높음 — EUC-KR·GPKI·한국 호스팅	높음 — 정상도구·터널링 LotL

2. 배경 - Kimsuky 와 두 악성코드 계열

Kimsuky는 Kaspersky가 2013년 최초 식별한 한국어 구사 APT 그룹으로, 10년 이상 활동해 왔다. 다른 북한 연계 그룹 대비 기술적 정교함은 상대적으로 낮다고 평가되지만, **표적 맞춤형 스피어피싱 제작 능력**에서 뛰어난 면모를 보인다. 보유 무기군에는 PebbleDash, BabyShark, AppleSeed, RandomQuery 등 자체 제작 악성코드와 xRAT·XenoRAT·TutRAT 같은 오픈소스 RAT가 포함된다.

주목할 점은 **PebbleDash가 본래 Lazarus Group이 사용하던 플랫폼이었으나**, Kimsuky가 최소 2021년부터 이를 전용(appropriate)해 자체 변종을 지속적으로 파생시켜 왔다는 것이다. 본 보고서가 다루는 두 계열의 특성은 아래와 같다.

구분	PebbleDash 계열	AppleSeed 계열
최초 확인	Lazarus 기원 → 2021년부터 Kimsuky 전용	2019년 (현재 관측 버전 2.1)
주요 표적	국방·군·의료 (전 세계, 한국 외 브라질·독일 포함)	정부 기관 (주로 한국)
핵심 역량	고도화된 원격 제어 백도어	정보 탈취 (문서·스크린샷·키로깅·GPKI 인증서)
배포 형식	JSE/EXE/SCR/PIF 드롭퍼 (양 계열 공통)	JSE 드롭퍼 위주

양 계열은 배포 방식(JSE·EXE·SCR·PIF 드롭퍼)이 겹치고, 표적이 점차 수렴 중

동일한 탈취 인증서로 서명되고 동일 뮤텍스 패턴을 공유한다. Kaspersky는 이를 근거로 단일 행위자가 두 계열을 모두 통제하며 필요에 따라 코드를 수정할 능력이 있다고 **중상(Medium-High) 신뢰 수준**으로 평가하고 있다.

3. 위협 행위자 프로파일 - Kimsuky(김수키)

본 장은 PebbleDash·AppleSeed 분석의 맥락을 잡기 위해, 위협 행위자 **Kimsuky(김수키)** 조직 자체의 정체성·연혁·주요 해킹 사건을 정리한다. 공개 보도와 국내외 기관 발표를 종합한 것이며, 본 보고서의 기술 분석(2·4장)과 함께 읽으면 이 그룹의 지속성·표적 선정 논리를 이해하는 데 도움이 된다.

3.1 조직 개요와 별칭

Kimsuky는 북한 **정찰총국(RGB) 산하**로 알려진 국가 배후 해킹 조직이다. 2012년경 한국·미국 등에 대한 사이버 공격을 목적으로 조직된 것으로 알려졌다. 카스퍼스키가 2013년 한·일·미·중의 국방 관련 민감 정보를 탈취하던 공격 그룹을 분석하는 과정에서 "Kimsuky"라는 이름을 명명했다. 라자루스(소니픽처스)·블루노로프(방글라데시 은행)가 대형 단발 사건으로 알려진 것과 달리, Kimsuky는 **매일같이 잔잔하게 지속하는 첩보형 공격**이 특징이다.

이름의 유래도 흥미롭다. 2013년 카스퍼스키가 북한 해커의 이메일 계정에서 따온 "**Kimsukyang(김숙양)**" 보고서를 발표했는데, 뒤의 "ang"을 떼어내 "Kimsuky"로 축약하면서 지금의 이름이 됐다. 쉽게 말해 Kimsuky는 "**정찰총국이 운영하는 국가 사이버 첩보 부대**"로, 무기를 든 군대가 아니라 키보드로 정보를 빼내는 군대 조직이다.

동일 조직이 보안 업체·정부별로 여러 이름으로 추적된다. 대표 별칭은 다음과 같다.

구분	명칭
Mandiant	APT43
Microsoft	Emerald Sleet (구 THALLIUM/탈룸)
CrowdStrike	Velvet Chollima (벨벳천리마)
기타	Black Banshee, Archipelago(아키펠라고), Sparkling Pisces, Springtail, Ruby Sleet 등

3.2 표적과 전략적 목적

Kimsuky의 수집 우선순위는 RGB의 임무, 즉 **북한의 외교·안보·핵 전략을 뒷받침하는 정보 획득**에 맞춰져 있다. 10년 넘게 한국·미국의 정부 기관, 외교·안보 싱크탱크, 방위산업체, 학술기관을 표적으로 삼아 왔으며, 정치인·정부 관계자·언론인·인권 활동가·탈북자 등 개인도 노리고 있다.

- 2020년 10월 이전: 한반도 외교·안보 정책 관련 정부·외교기관·싱크탱크 집중.
- 2020.10~2021.10: **코로나19 대응** 관련 의료·제약 분야로 일시 전환 — 평양의 우선순위 변화에 즉각 반응.
- 자금 조달: 탈취한 개인정보·기관 컴퓨팅 파워로 **암호화폐 채굴·세탁**에도 관여(채굴 파워 구매로 온체인 추적 회피).

핵심 무기는 **맞춤형 사회공학 + 정교한 악성코드 프레임워크의 결합**이다. 학술 콘퍼런스 초청·논문 검토 요청·인터뷰 제안 등으로 신뢰를 얻은 뒤 스피어피싱으로 침투하는 패턴이 반복되고 있다.

3.3 주요 해킹 사건 연혁

시기	사건	내용·의미
2013	청와대·정부 사칭 악성메일	HWP 취약점 악용, mail.bg 등 C2 — 이후 공격의 원형
2014	한국수력원자력(한수원) 해킹	원전 도면 유출·가동중지 협박, 조직명을 대중에 각인
2016	청와대·통일부·외교부 사칭 메일	4차 핵실험·사드 관련, 한수원과 동일 계정(sntongil12)
2021	원자력연구원·KAI·대우조선·서울대병원	원자력·방산·우주·의료 등 국가 핵심기술 광범위 표적
2021.04	중앙선거관리위원회 PC 침해	대외비 문건 유출, 2023년 합동 보안점검에서 뒤늦게 확인
2022.12	태영호 의원실 사칭 피싱	국방·외교·통일 전문가·기관 표적, 기자 사칭 수법
2023	한미연합훈련 연계 공격 / stake.com	훈련 시점 맞춘 공격, 이더리움 약 4.1억 달러 탈취
2024	SBS 기자·연세대 교수·통일부 사칭	일본 외무성·북한인권대사 사칭 등 다국적 스피어피싱
2025	서울시민 계정 악용 / KT·LGU+ 의혹	건강검진서·은행·기관 위장 악성메일, 통신사 침해 연루
2026.01	악성 QR코드 피싱(규상)	FBI 경보 — 설문·행사 링크 위장, 비번·지문 등 탈취

3.4 김수키, 이 조직은 얼마나 위험한가?

Kimsuky가 위험한 이유는 단발성 "대형 사고"가 아니라, **국가 차원의 첩보를 10년 넘게 멈추지 않고 수행**한다는 데 있다. 일반에 잘 알려지지 않은 것은 이들이 은행을 털어 헤드라인을 장식하는 라자루스와 달리, 조용히 정보를 빼내는 "그림자형" 조직이기 때문이다. 그러나 그 표적과 파급력은 결코 가볍지 않다.

- **국가 안보 직결:** 원전(한수원)·원자력연구원·방산(KAI)·우주 기술을 노려 북한의 무기·위성 개발에 직간접 기여. 핵심 기술 유출은 국가 안보에 직접적 위협이다.
- **민주주의 기반 침해:** 2021년 중앙선거관리위원회 PC가 악성코드에 감염돼 대외비 문건이 유출됐고, 이는 2023년 합동 보안점검에서야 드러났다 — 침투의 은밀성과 장기 잠복을 보여주는 사례.
- **개인을 노리는 정밀 사회공학:** 기자·교수·외교관·정부 관리를 사칭하고, 언론사 사이트를 그대로 복제하며, 이메일 주소를 한 글자만 바꿔 속인다. 보안 전문가조차 식별이 쉽지 않은 신종 악성파일을 사용한다.
- **국경을 넘는 표적:** 한국뿐 아니라 미국·영국·일본의 정부·연구기관·언론을 노리며, 자유아시아방송·일본 외무성 사칭 등 다국적 공작을 수행한다.
- **자금 조달형 공격 병행:** 정보 탈취에 더해 stake.com 약 4.1억 달러 규모 암호화폐 탈취 등 금전 확보에도 가담 — 제재 회피와 정권 자금줄 역할.
- **끊임없는 진화:** 코로나19 시기엔 백신 정보를, 2026년엔 QR코드 피싱(큐싱)을 도입하는 등 사회 이슈와 기술 트렌드에 맞춰 수법을 즉각 갈아타고 있다.

⚠️ 핵심

Kimsuky의 진짜 위협은 "화려함"이 아니라 **지속성·은밀성·표적의 정밀함**이다. 정부·연구기관·언론·전문가 개인이라면 누구나 표적이 될 수 있으며, 한 번의 부주의한 클릭이 국가 기밀 유출로 이어질 수 있다.

본 보고서가 다루는 PebbleDash·AppleSeed 캠페인은 이 오래된 위협이 **Rust·AI·터널링으로 더 정교해진 2026년의 얼굴**이다.

3.5 제재 및 국제 대응 동향

- 2023.06: 대한민국 정부가 **세계 최초로 Kimsuky를 대북 독자제재 대상으로 지정**. 한미 양국은 합동 보안주의보를 발령.
- 2024.05: 미국 정부가 Kimsuky 주의보를 추가 발령.
- 2026.01: FBI가 악성 QR코드 표적 피싱에 대해 긴급 경보 — 수법 고도화 경고.
- 학계·업계: 카스퍼스키·Genians·이스트시큐리티·고려대 정보보호대학원 등이 지속 추적·분석 공개 중.

▶ **본 보고서와의 연결** 위 연혁에서 드러나는 일관된 패턴, 한국 정부·국방·의료·학술 표적, 한국어 사회공학, HWP/문서 위장, 한국 인프라 활용은 본 보고서가 다루는 **PebbleDash·AppleSeed 캠페인(2025~2026)에서 그대로 재현된다**. 즉 신규 Rust 백도어(HelloDoor)나 VSCode 터널링 같은 도구는 새롭지만, 표적 선정과 작전 논리는 10년 넘게 이어진 Kimsuky의 연속선상에 있다.

4. 초기 침투 (Initial Access)

Kimsuky는 수신자가 첨부파일을 열도록 정교하게 제작한 스피어피싱 이메일을 발송하며, 경우에 따라 메신저로 직접 접근하기도 한다. 첨부파일은 주로 **드롭퍼를 담은 압축 파일**이며, 제품 견적서, 채용 공고, 안내문, 설문지, 정부 문서, 개인 사진 등으로 위장한다. 최근 탐지된 실제 미끼 사례는 다음과 같다.

#	파일명 (위장 주제)	탐지일	전달 악성코드
1	[별지 제8호서식] 개인정보 요구서 (개인정보보호법 시행규칙).hwp.jse	2025-08-28	HelloDoor
2	2026년 상반기 국내대학원 석사야간과정 위탁교육생 선발 서류.hwp.x.jse	2025-12-14	httpMalice
3	security_20260126.scr	2026-01-26	Reger Dropper → MemLoad → httpTroy
4	노현정님.pdf.jse	2026-01-28	AppleSeed chain
5	대국민서비스관리운영체계 현장점검 증적(초안).pif	2026-02-05	Pidoc Dropper → HappyDoor

주목할 점은 미끼 파일명이 **실제 한국 공공 행정, 교육, 개인정보 행정문서를 정밀하게 모사**한다는 것이다. 한국 행정 용어에 대한 깊은 이해를 전제로 하며, 이는 표적 선정과 사회공학의 정밀도를 보여준다.

정밀한 해킹 기술보다 한국 사회의 이해를 바탕으로 사회 공학적 해킹이 주요 방법이다.

4.1 드롭퍼 실행 메커니즘

- **JSE 드롭퍼**: 최소 2 개의 Base64 블록(미끼 문서 + 악성 페이로드)을 포함. JScript 로 디코딩해 C:\ProgramData 에 [random]{7}.[random]{4} 형식으로 저장. 미끼 문서를 즉시 열어 위장하고, 페이로드는 powershell.exe -windowstyle hidden certutil -decode 로 2 차 디코딩 후 regsvr32.exe /s 또는 rundll32.exe 로 실행.
- **Reger Dropper (.SCR)**: 하드코딩 XOR 키 #RsfsetraW#@EsfesgsgAJOPj4em1; 사용.
- **Pidoc Dropper (.PIF)**: 단일 바이트 XOR(0xFF), 더미 데이터·암호화 문자열로 완전 난독화.

5. 신규 악성코드 심층 분석

5.1 HelloDoor — Kimsuky 최초의 Rust 기반 백도어

HelloDoor는 2025년 8월 최초 식별된 **Rust 언어 DLL 백도어**로, Kimsuky가 거의 사용하지 않던 언어라는 점에서 가장 주목할 만하다. 기능이 제한적이고 통신 구조가 단순해 **개발 초기 단계**로 평가할 수 있다.

지속성	HKCU\...\Run 키에 값명 td11 등록 (regsvr32.exe /s)
C2 통신	HTTP / TryCloudflare 임시 터널 (계정·설정 불필요 → 추적 곤란)
토큰별 포트	권한 상승 시 5555, 미상승 시 5554 바인딩
암호화	서버 응답 Base64 디코딩 후 RC4 복호화 (키: fwr3errsettwererfs)
쿼리 포맷	aaaaaaaaa=2&bbbbbbbbbb=[UID]&ccccccccc=1 — PebbleDash 계열 전용 포맷

⚠ LLM 생성 코드 정황

HelloDoor 코드에는 인간 프로그래머보다 LLM 서비스가 생성한 것으로 보이는 디버그 로그(이모지 포함: ✅ 포트 리스닝, ❌ 포트 사용 중, 🔍 regsvr32 부모 프로세스 탐지 등)가 발견되었다.

동시에 "result send fail", "decryption failed", "autorun failed" 같은 문법 오류·오타도 남아 있어, AI 생성 후 사람이 수동 편집한 흔적으로 해석할 수 있다.

Kaspersky는 BlueNoroff의 PowerShell 스틸러에서도 유사 오타와 개발 스타일을 관측한 바 있다. (김수키 특유의 오타 패턴)

5.2 httpMalice — 최신 PebbleDash 백도어 변종

httpMalice는 2025년 12월경 등장한 최신 PebbleDash 기반 백도어다. 두 버전이 확인되며 **v1.9는 HTTP/HTTPS**, 구버전 **v1.8은 Dropbox API**를 C2 채널로 사용한다.

- 권한에 따라 지속성 분기: 상승 시 CacheDB 서비스 생성(표시명 Administrator), 미상승 시 HKCU\...\Run 에 값명 Everything 1.9a-[filesize] 등록.
- 호스트 프로파일링 시 chcp 949 (EUC-KR 코드페이지)를 사용 → **한국어 사용자 표적임을 명확히 시사.**
- 데이터는 **ChaCha20** 암호화 후 Base64 인코딩. 키·논스를 버퍼 포인터 주소에서 파생해 거의 무작위화하며, 복호화를 위해 논스·키를 암호문 뒤에 덧붙임.

- UID 포맷: [volume serial]{8}_{elevation status}. C2 통신은 m= 파라미터 기반 모드(1=세션, 2=명령요청, 12=스크린샷, 13=장비정보 등) 13 중 운용.

PebbleDash와 AppleSeed 양 계열의 특성을 모두 보유한다는 점(고무결성 SID s-1-12-12288 명령 실행은 PebbleDash, m= 파라미터·PowerShell 시스템 정보 수집은 AppleSeed)에서 두 계열이 단일 행위자에게 통제됨을 다시 확인할 수 있다.

5.3 MemLoad → httpTroy 체인

MemLoad는 탐지 회피용 로더로, 안티-VM 체크와 정찰을 통해 표적 가치를 평가한 뒤에야 최종 백도어를 **메모리에 리플렉티브 로딩**한다. 2025년 초부터 V2(3월)·V3(9월)가 관측됐으며, 올해 Reger Dropper로 배포된 변종은 V3의 소폭 수정판으로 볼 수 있다.

- 지속성: 권한 상승 시 스케줄 작업명 ChromeCheck, 미상승 시 EdgeCheck (1 분 주기 regsvr32 실행).
- ID 생성: system32 쓰기 성공 여부로 권한 판별 → A-(관리자) 또는 U-(일반) 접두.
- RC4 키 #RsfsetraW#@EsfesgsgAJ0Pj4em1;로 페이로드 복호화 후 hello export 호출 — 이 키는 Reger Dropper 와 동일.

최종 페이로드는 장기 접근·데이터 유출을 담당하는 **httpTroy** 백도어다. ADS(대체 데이터 스트림) [path]:HUI 영역에 플래그 파일을 생성하며, C2는 file.bigcloud.n-e[.]kr이다.

5.4 AppleSeed 계열 — GPKI 인증서 탈취의 시그니처화

AppleSeed는 2019년 등장해 3.0까지 발전했으나 현재는 2.1 버전이 관측된다. Dropper형(추가 악성코드 다운로드·명령 실행)과 Spy형(문서·스크린샷·키로깅·USB 목록 수집)으로 나뉜다.

2022년부터의 핵심 변화는 **C:WGPKI 디렉터리 수집** 기능이다. 이 경로는 한국 정부가 공무원·정부 시스템 인증에 쓰는 디지털 인증서를 담고 있어, 국가 행정 침투 측면에서 위험도가 매우 높다. 동일 기능은 Troll Stealer에도 구현되어 있다.

HappyDoor는 AhnLab이 2024년 공개한 AppleSeed 기반 백도어로, 동일 문자열 난독화 알고리즘·수집

데이터 유형-RSA 암호화를 공유한다. Kaspersky는 이를 AppleSeed에서 진화한 고도 변종으로 **중간 (Medium) 신뢰 수준**에서 평가할 수 있다.

6. 분석 초점 - 왜 Rust 였는가?

HelloDoor가 Kimsuky 최초의 Rust 백도어라는 사실 자체보다, **"왜 지금, 굳이 Rust인가"**라는 질문이 위협의 방향성을 더 잘 드러낸다. 단일 동기로 보기 어렵고, 탐지 회피, 개발 편의, 공급 현실이 겹친 결과로 평가할 수 있다. 더럽게 개발환경이 짜증스러운 Rust로 짰 이유는 명확하다.

6.1 탐지 회피 - 기존 시그니처의 무력화

가장 설득력 있는 동기다. C/C++로 수년간 축적된 PebbleDash의 바이너리 시그니처와 YARA 룰은 이미 백신, EDR에 학습되어 있다. 동일 기능이라도 Rust로 재작성하면 **컴파일 산출물의 구조 자체가 달라진다**. Rust는 런타임을 정적 링크해 바이너리가 비대해지고, 함수 경계·문자열 배치·제어 흐름이 C 계열과 다르게 나오며, 패닉 처리 루틴과 고유한 이름 망글링(name mangling) 심볼이 섞인다. 분석가에게는 디컴파일 결과가 훨씬 지저분해지고, 기존 탐지 룰이 그대로 적용하지 않는다.

즉 같은 백도어에 **"새 옷"**을 입혀 탐지 곡선을 리셋하는 효과다. 이는 Kimsuky만의 발상이 아니라 Lazarus·BlueNoroff를 포함한 다수 APT에서 최근 수년간 공통 관측된 Rust-Go 이주 흐름과 궤를 같이하고 있다.

6.2 LLM 보조 개발 - 진입 장벽을 낮춘 AI

이 챕터의 핵심은 4.1에서 짚은 LLM 흔적과 직결된다. HelloDoor 코드에 LLM이 생성한 듯한 이모지 디버그 로그와 함께 "decryption failed", "autorun failed" 같은 잔존 오타가 공존한다는 점은, 개발자가 **익숙하지 않은 언어를 AI 보조로 처음 다뤘을 가능성**을 시사하고 있다.

Rust는 소유권(ownership), borrow checker로 진입 장벽이 높기로 유명한데, LLM이 그 학습 비용을 크게 낮춰줄 수 있다. "Rust로 짜고 싶지만 숙련자가 없다"는 제약을 AI가 메워준 셈이다.

순수한 인간 Rust 전문가의 산출물이었다면 그런 어설픈 흔적은 남지 않았을 것이다. 이는 북한 위협 행

위자가 AI로 개발 생산성은 끌어올리되, 아직 완전 자동화에는 이르지 못한 과도기에 있음을 보여주고 있다. 오염된 LLM에게 악성 코드를 만들도록 하는 행위는 아직까지 여러 제약이 있다.

6.3 부차적 동기 - Rust 자체의 이점(단, 현재는 제한적)

- 메모리 안전성으로 크래시가 줄어 백도어 안정성·은밀성 향상.
- 크로스 플랫폼 컴파일과 풍부한 crates 생태계로 네트워킹·암호화 기능을 빠르게 결합.
- 정적 링크로 외부 의존성이 적어 표적 환경 배포가 용이.

다만 HelloDoor는 기능이 단순하고 통신 구조도 빈약한 초기 단계 산출물이므로, 이 시점에서 안정성이 주된 동기였다고 보기는 어렵다. 핵심 동기는 **탐지 회피, 그리고 그것을 가능케 한 AI 보조 개발**의 조합으로 평가할 수 있다. 북한산 RAT의 경우 메모리 관리를 제대로하지 않아 저사양 컴퓨터가 주로 있는 공공 기관에서 작동 불능에 빠트리는 경향이 있었다.

▶ 방어자가 주목할 신호

진짜 중요한 것은 "왜 Rust냐"보다 **향후 6~12개월 내 PebbleDash 핵심 백도어(httpMalice급)까지 Rust로 재작성되는지** 추적하는 것이다.

Kaspersky도 "아직 다른 Rust 악성코드는 발견되지 않았다"며 초기 단계로 못 박았다. 본격 이주가 확인되는 시점이 오면, 시그니처 기반 탐지의 상당 부분을 다시 설계해야 할 수 있다.

7. 후속 침투 - 정상 도구(LotL) 악용

Kimsuky는 백도어가 보안 제품에 탐지될 것을 대비해 **정상 도구를 이용한 우회 경로**를 병행 준비했다. 관측된 VSCode 드롭퍼는 PebbleDash와 동일한 미끼 파일을 사용해, 두 경로가 동일 캠페인의 분기임을 보여주고 있다.

7.1 VSCode 원격 터널링 악용

정상 Visual Studio Code의 Remote Tunneling 기능을 악용해 은닉 원격 접근을 구축하고 있다. 악성코드를 떨구는 대신 정상 VSCode CLI를 내려받아 터널을 생성하므로 **탐지 지점이 현저히 적다**. 인증은 비대화형 컨텍스트

트에서 기본 제공자인 **GitHub 계정**으로 자동 선택된다.

- JSE 드롭퍼 방식: 터널명 bizeugene 사용, echo |로 표준입력에 개행을 주입해 기본 프롬프트 자동 확정. 생성된 `vscode.dev/tunnel` URL·디바이스 코드를 탈취된 한국 사이트(`yespp.co[.]kr`)로 POST 전송.
- 신규 Go 작성 설치기(`vscode_payload`): 모든 터널명 지원으로 범용화. 디버그·터널 URL 을 **Slack WebHook** 으로 전송(+++ I am started +++, ~~~ I am alive ~~~ 등).

결과적으로 표적 장비는 **Microsoft 소유 서버**와 통신하게 되어, 사용자는 그 트래픽이 공격자로부터 비롯된 것임을 인지하지 못하게 된다.

7.2 DWAgent 원격 관리 도구 악용

DWAgent는 정상 원격 관리(RMM) 도구로, 랜섬웨어·APT가 흔히 악용한다. Kimsuky는 (1) httpMalice 감염 호스트에 압축 파일+명령을 전달해 설치하거나 (2) 별도 설치기를 제작한다.

설치기는 Reger Dropper와 동일 RC4 키·코드 구조를 가지며, 공격자 계정에 연결된 `config.json`으로 즉시 원격 세션을 활성화한다(정상 DWService 릴레이 서버 `node*.dwservice[.]net` 경유).

8. 인프라 및 피해 양상

Kimsuky는 수년째 한국 무료 도메인 호스팅 서비스 **내도메인.한국**(`.p-e.kr`, `.o-r.kr`, `.n-e.kr`, `.r-e.kr`, `.kro.kr` 등)을 정상 사이트 모사에 활용하며, 배후 인프라는 대부분 InterServer VPS로 해석된다.

다만 이 서비스는 다수 악성 행위자가 함께 악용하므로 단독으로는 Kimsuky 귀속 근거가 되지 못한다. 추가로 탈취한 한국 정상 웹사이트를 C2로 삼고, Cloudflare Quick Tunnel·VSCode·Ngrok 터널링으로 인프라를 은닉한다.

피해 분석에서 httpMalice의 Dropbox C2에 업로드된 감염 로그가 다수 발견됐는데, 각 피해자 폴더에 `user.txt` 파일이 있었다. 여기에는 표적 정보, http 백도어 존재 여부, DWAgent 존재 여부, 장비-표적 관

계가 평문 텍스트 **한국어로** 기록되어(예: "장악", "http 있음", "DWService 있음"), 공격자가 수동으로 피해자를 관리한 정황을 보여주고 있다.

8.1 귀속 (Attribution)

- 양 계열 다수 샘플이 **동일 탈취 인증서로 서명**되고 동일 뮤텍스 패턴 공유.
- PebbleDash 는 2021 년 이래 Kimsuky 공격에서만 배타적으로 발견; AppleSeed 는 등장 이래 Kimsuky 에 연계.
- Microsoft **Ruby Sleet**, Mandiant **Cerium** → **APT43** 등 명칭과 기술적으로 연결.
- 종합 평가: **중상(Medium-High) 신뢰 수준에서 Kimsuky 연계 클러스터 소행.**

9. MITRE ATT&CK 매핑

전술 (Tactic)	기법 (Technique)	관측 내용
Initial Access	T1566.001 Spearphishing Attachment	문서 위장 JSE/PIF/SCR 첨부
Execution	T1059.001/.007 PowerShell/JScript	certutil 디코딩, JScript 드롭퍼
Execution	T1218.010/.011 Regsvr32/Rundll32	페이로드 실행 (LOLBin)
Persistence	T1547.001 Run Keys	tdll, Everything 1.9a 등록
Persistence	T1543.003 Windows Service	CacheDB 서비스 생성
Persistence	T1053.005 Scheduled Task	ChromeCheck / EdgeCheck
Defense Evasion	T1620 Reflective Loading	MemLoad 메모리 로딩
Defense Evasion	T1553.002 Code Signing	탈취된 한국 기관 인증서
Defense Evasion	T1564.004 ADS	httpTroy :HUI 스트림
C2	T1572 Protocol Tunneling	VSCode-Cloudflare-Ngrok 터널
C2	T1102 Web Service	Dropbox-Slack WebHook C2
C2	T1219 Remote Access Software	DWAgent 악용
Collection	T1056.001 Keylogging	AppleSeed Spy
Exfiltration	T1041 Exfil over C2	GPKI 인증서-문서 유출

10. 탐지 및 대응 권고

10.1 즉시 탐지 포인트

- 이중 확장자 첨부(.hwp.jse, .pdf.jse, .scr, .pif)를 메일 게이트웨이에서 차단·격리.
- regsvr32.exe /s 및 rundll32.exe 가 C:\ProgramData 내 무작위명 파일을 실행하는 패턴 탐지.
- PowerShell 의 certutil -decode 호출 + -windowstyle hidden 조합 경보.
- 스케줄 작업 ChromeCheck/EdgeCheck 및 서비스 CacheDB 존재 점검.
- VSCode CLI(code.exe tunnel)의 비정상 실행, *.trycloudflare.com / vscode.dev/tunnel / *.dwservice.net 통신 모니터링.
- C:\GPKI 디렉터리에 대한 비인가 접근·압축·유출 시도 탐지 — 정부 기관 우선.

10.2 조직 차원 대응

- 내도메인.한국 계열 무료 도메인(.p-e.kr / .o-r.kr / .n-e.kr / .r-e.kr / .kro.kr)으로의 비업무 통신을 프록시·DNS 레벨에서 식별·검토.
- VSCode-DWAgent 등 RMM/개발 도구의 허용 목록(allowlisting) 및 GitHub 디바이스 인증 흐름 모니터링.
- 국방·정부·의료 부문은 **PebbleDash 계열 우선 표적**임을 인지하고 스피어피싱 모의훈련·EDR 룰을 강화.
- 부록 IOC 를 SIEM/EDR/방화벽에 즉시 적용하고, 과거 로그를 소급 점검(retro-hunt).

11. 한국 정부 및 관계 당국의 대책

Kimsuky는 한국 정부가 **세계 최초로 대북 독자제재 대상으로 지정**한 해킹 조직이다. 본 위협은 한국 특화 성격이 뚜렷한 만큼, 글로벌 IOC 수신에 그치지 말고 국내 신고·대응 체계를 적극 활용하는 것이 중요하다. 아래는 피해 의심 시 즉시 가동해야 할 공식 창구와 법적 의무라고 할 수 있다.

11.1 침해사고 신고 창구

정부는 북한 소행 스피어피싱 공격의 대상이 되었다고 판단될 경우, **실제 침해 발생 여부와 관계없이** 소관기관에 신고할 것을 권고한다.

기관	신고번호	역할
국가정보원	111	국가 배후 사이버위협 총괄, 공공·국가기반시설 대응
경찰청	182	사이버범죄 수사 및 형사 대응
한국인터넷진흥원(KISA)	118	민간분야 침해사고 신고 접수·원인분석·기술지원
보호나라 / KrCERT/CC	boho.or.kr	온라인 해킹·랜섬웨어 신고, 중소기업 피해지원

10.2 법적 신고 의무 (정보통신망법)

- 정보통신서비스 제공자는 **정보통신망법 제 48 조의 3**에 따라 침해사고 발생을 알게 된 때부터 **24 시간 이내**에 과학기술정보통신부장관 또는 KISA에 신고해야 한다.
- 24 시간 경과 후 신고하거나 미신고 시, 동법 제 76 조에 따라 **3 천만원 이하 과태료** 부과 대상이 된다.
- 제 48 조의 4에 따라 침해사고 관련 자료 보존·제출 및 현장조사 협조 의무가 있으며, 자료 미제출·거짓 제출 시 1 천만원 이하 과태료가 부과될 수 있다.
- 해킹으로 **개인정보 유출**이 동반된 경우, 개인정보보호법에 따른 **개인정보 유출 신고**를 침해사고 신고와 별도로 접수해야 한다.

10.3 정부의 선제적, 외교적 대응

- **대북 독자제재**: 정부는 김수기를 독자제재 대상으로 지정했으며, 북한 IT 인력에 대한 한미 공동 독자제재와 연계해 단호한 대응 의지를 표명해야 한다.
- **한미 공조 및 국제 협력**: 미국 등 국제사회와의 공조를 바탕으로 북한 불법 사이버활동에 대한 경각심 제고와 합동 주의보 발령을 지속하고 있다.
- **민관 위협정보 공유**: KISA의 **C-TAS(사이버 위협정보 분석·공유 시스템)**를 통해 위협 인텔리전스를 공유하고, 긴급 시 실시간 상황전파 체계를 운영한다.
- **사이버 위기경보**: 정상-관심-주의-경계-심각 5 단계 경보 체계를 운용하며, 단계별 조치사항을 안내한다.

▶ 권고

정부·국방·의료 등 PebbleDash 우선 표적 부문은 본 보고서의 IOC를 C-TAS 및 자체 EDR에 즉시 반영하고, GPKI 인증서 접근 행위에 대한 별도 감사 로그를 활성화할 것을 권고한다.

침해 의심 시 24시간 신고 의무를 준수하고, 증거 보존을 위해 감염 추정 시스템의 메모리·디스크 이미지를 우선 확보해야 한다.

12. 분석가 평가 (Analyst Assessment)

이번 캠페인의 의미는 Kimsuky가 인공지능 LLM을 통해 "덜 정교한 그룹"이라는 통념을 빠르게 갱신하고 있다는 데 있다. Rust 채택, 정상 클라우드 개발 도구의 LotL 악용, 터널링을 통한 인프라 은닉은 모두 탐지·귀속을 어렵게 만드는 방향의 진화의 모습이다.

특히 **LLM 생성 코드 정황**은 본 분석가가 주목하는 지점이다. 이는 북한 위협 행위자가 AI를 활용해 **개발 생산성을 끌어올리되, 아직 완전 자동화 단계에는 이르지 못한 과도기에** 있음을 시사하고 있다.

Kaspersky 역시 "AI가 일부 공격의 완전 자동화를 제공할 수 있으나, 많은 그룹은 수년간 써온 도구·전략을 고수하며, 완전 자동화된 공격 구성은 결코 사소한 일이 아니다"라고 평가할 수 있다. 즉 **AI는 위협을 가속하지만 대체하지는 않으며**, 방어자에게도 악성코드·초기 벡터·표적·후속 활동·궁극 목표를 종합 추적하는 전통적 접근의 가치는 여전히 유효하다고 할 수 있다.

한국 정부의 관점의 시사점은 명확하다.

EUC-KR 코드페이지 표적화, 한국 행정문서 정밀 모사, GPKI 인증서 탈취, 한국 무료 호스팅·탈취 사이트 C2 등 **이 위협은 본질적으로 한국 특화다**.

글로벌 벤더의 IOC를 수동적으로 수신하는 데 그치지 말고, 한국어 미끼 패턴과 GPKI 접근 행위 같은 국지적 탐지 로직을 자체 구축하는 것이 핵심 대응이다.

부록 A. 침해 지표 (IOC)

A.1 파일 해시 (MD5)

분류	MD5	비고
JSE Dropper	995a0a49ae4b244928b3f67e2bfd7a6e	→HelloDoor
JSE Dropper	52f1ff082e981cbdfd1f045c6021c63f	→httpMalice
JSE Dropper	9fe43e08c8f446554340f972dac8a68c	→httpMalice
JSE Dropper	8e15c4d4f71bdd9dbc48cd2cab87806	→AppleSeed
Reger Dropper	65fc9f06de5603e2c1af9b4f288bb22c	security_*.scr
Reger Dropper	c19aeaedbbfc4e029f7e9bdface495b9	secu.scr
Pidoc Dropper	8983ffa6da23e0b99ccc58c17b9788c7	.pif
AppleSeed	a7f0a18ac87e982d6f32f7a715e12532	Dropper
AppleSeed	f4465403f9693939fe9c439f0ab33610	Dropper
AppleSeed	5c373c2116ab4a615e622f577e22e9be	Dropper
HappyDoor	d1ec20144c83bba921243e72c517da5e	
MemLoad	58ac2f65e335922be3f60e57099dc8a3	
MemLoad	f73ba062116ea9f37d072aa41c7f5108	jhsakqv.dat
httpTroy	7e0825019d0de0c1c4a1673f94043ddb	config.db
httpMalice	08160acf08fcccde7b34090db18b321	
httpMalice	94faed9af49c98a89c8acc55e97276c9	
HelloDoor	c42ae004badddd3017adadbdd1421e00	
VSCode 설치기	9ca5f93a732f404bbb2cee848f5bbda0	xipbkma.exe
DWAgent 설치기	678fb1a87af525c33ba2492552d5c0e2	

A.2 도메인 및 C2

지표 (Indicator)	유형	연관 악성코드
opedromos1.r-e[.]kr	Domain	AppleSeed C2
morames.r-e[.]kr	Domain	AppleSeed C2
load.ssangyongcne.o-r[.]kr	Domain	MemLoad C2
load.yju.o-r[.]kr	Domain	MemLoad C2

지표 (Indicator)	유형	연관 악성코드
attach.docucloud.o-r[.]kr	Domain	MemLoad C2
load.supershop.o-r[.]kr	Domain	MemLoad C2
load.erasecloud.n-e[.]kr	Domain	MemLoad C2
cms.spaceyou.o-r[.]kr	Domain	HappyDoor C2
erp.spaceme.p-e[.]kr	Domain	HappyDoor C2
file.bigcloud.n-e[.]kr	Domain	httpTroy C2
load.auraria[.]org	Domain	httpTroy C2
female-disorder-beta-metropolitan.trycloudflare[.]com	Tunnel	HelloDoor C2
www.pyrotech.co[.]kr/.../default.php	탈취 사이트	httpMalice C2
newjo-imd[.]com/.../default.php	탈취 사이트	httpMalice C2
www.yespp.co[.]kr/.../out.php	탈취 사이트	VSCode 터널 탈취

※ 위 지표는 Kaspersky GReAT의 공개 분석(2026-05-14)에 기반한다. 방어 목적 외 사용을 금하며, 적용 전 자사 환경에서의 오탐 가능성을 검토할 것을 권고한다.

부록 B. 출처

- [1] Kaspersky GReAT (Sojun Ryu), "[Kimsuky targets organizations with PebbleDash-based tools](#)", Securelist, 2026-05-14.
- [2] Gen Digital Threat Labs, "DPRK's Playbook: Kimsuky's HttpTroy and Lazarus's New BLINDINGCAN Variant", 2025-10.
- [3] AhnLab ASEC, HappyDoor 분석 보고서, 2024.
- [4] Microsoft, "Latest intelligence on North Korean and Chinese threat actors" (Ruby Sleet), CyberWarCon, 2024-11.
- [5] Mandiant/Google Cloud, "APT43 / Mapping DPRK Groups to Government".

작성: Dennis Kim (김호광), Betalabs Inc. / 독립 CTI 분석가.

배포: github.com/gameworkerkim/CYBER-THREAT-INTELLIGENCE-REPORT. 본 문서는 공개 출처 정보(OSINT)를 종합·재구성한 위협 인텔리전스 분석이며, 방어 목적의 정보 공유를 위해 작성되었다. 모든 1차 기술 분석의 출처는 Kaspersky GReAT이며, 작성자의 해석·평가가 부가되어 있다.